個人情報漏えい 机上訓練

資料の構成・実施設定・事前準備

社内資料 | 実施日 2026-10-02（金）15:00 - 16:00 | 株式会社STANDS

管理画面のログインレポートCSVダウンロード機能の不具合で、顧客が自分でダウンロードしたCSVに
他社プロダクトのデータが混入していた、という想定で行う60分の机上訓練一式。
実システムには一切触らない。主催側からは会議を設定せず、すべてSlackで行う。

成果物は「うまく対応できたかの評価」ではなく「決められなかったことのリスト」。
当社には対応フローも CSIRT 相当の組織も無いため、この訓練は
フローに何を書くべきかを洗い出す要件定義として実施する。参加者が詰まるほど成功。

> **取扱注意**: 進行台本と Slack投入用テキストは**ファシリテーターのみ**が持つ。
> 参加者に渡してよいのは、訓練終了後の**参加者配布資料だけ**。

ファイル

ファイル	何のためのものか	持つ人	使うタイミング
00_訓練の概要と準備.pdf（本書）	この索引。決定事項と進め方の入口	全員	最初に読む
01_ファシリテーター用進行台本.pdf	**進行台本。まずこれを読む。** 事前準備・役割・タイムテーブル・各インジェクトの投げる問いと誘導セリフ・振り返りの進め方・訓練後の宿題まで	ファシリテーターのみ	準備〜当日〜事後
02_Slack投入用テキスト.pdf	**Slackにコピペする文面集。** 当事者役へのDM・第一報・集計結果・投票・続報・ネタバラシ、および参加者の返信に対する応答パターン集	ファシリテーターのみ	当日、手元に開いておく
2026-09-07_incident-drill-retrospective-sheet.xlsx	**記入用の振り返り／チェックシート（Excel）。** 時系列・測定値・集約・確認漏れチェック・アクション化	記録係・ファシリテーター	訓練中〜訓練後
07_インシデント対応フロー_ドラフト.pdf	**対応フロー（ドラフト）。** フェーズ別の本編＋役割別チェックリスト4枚＋要決定事項の一覧	全員	レビュー中
2026-10-02_action-plan.md	**アクション管理。** 見つかった空白を担当・期限付きのアクションに変換して追跡する。**担当と期限はこれが正**	ファシリテーター	訓練後〜フロー確定まで
04_訓練実施報告.pdf	**実施報告。** 測定結果・よくできていたこと・見つかった空白8点・今後の予定	参加者全員	訓練終了後に配布
2026-10-02_post-drill-survey-form.md	**訓練後アンケート（Googleフォーム）のテンプレート。** 設問一覧・Apps Script・回答後の集約手順	ファシリテーター	訓練終了後
03_参加者配布資料.pdf	**参加者配布資料。** 各場面の正解に近い動き・個人情報保護法の要点・やりがちな失敗・明日からのお願い	参加者全員	**訓練終了後に**配布

Excel シートの中身

シート	記入する人	タイミング
表紙・実施概要	ファシリテーター	事前
Part1 時系列・測定値	記録係	訓練中はSlackに残らないものだけメモ、残りは終了後に復元
Part2 確認漏れチェック	ファシリテーター	アンケートの集約後

xlsx が持つのはこの2つだけ。**個人記入とその集約は Googleフォームの回答スプレッドシート**、**アクション（担当・期限・状態）は** `2026-10-02_action-plan.md` で管理する。

今回の実施設定

項目	決定
実施モード	**モードC（Slack完結型）** — **主催側からは会議を設定しない。** 開始・終了ともSlackで告知し、振り返りもスレッドで完結（参加者が自分でハドルを立てるのは自由）
抜き打ち度	予告あり（「◯時から1時間、机上訓練をやります。こちらからは会議を設定しません」とだけ伝える）
所要時間	60分（インジェクト⑤を足す75分版あり）
訓練用チャンネル	`#2026_個人情報漏えい訓練`（トピックに `【訓練用】ONBS-1998 机上訓練専用`）。**A社との共有チャンネル想定であることを開始告知で明示する**
社内対応チャンネル	**あえて用意しない。** 参加者が自分で作るかが観測点
実施日時	**2026-10-02（金）15:00 - 16:00**

役割	担当
ファシリテーター（A社 田中さん役 / 記録係 兼任）	空 ／ **対応メンバーとしては「休暇で不在」の設定**
統括判断者	藤原（ISMS管理者）／ **シナリオを知らない訓練対象**（事前共有しない）
一次受け	椎名（CS）
調査担当	鈴木（エンジニア・**改修した本人役**）／ 文（エンジニア・**役の情報なし**）
（分担）	**割り当てない。** 誰が事実確認を引き取るかは観測点
オブザーバー	経営層1名（可能なら）・未定

進め方

いつ	やること	見るファイル
～10/1（木）	参加者へ案内（9/30まで）、チャンネル作成。**シナリオは誰にも事前共有しない**	台本「§2 事前準備」
10/2 14:50頃	鈴木さんへDMで役の情報を渡す	投入テキスト「開始直前 — 鈴木さんへのDM」
15:00	**Slackへ開始告知**（`@channel`。無罰宣言を含む）	投入テキスト「オープニング告知」
15:05～15:47	時刻どおりにSlackへインジェクト①～④を投入し、あとは観測（15:05 / 15:15 / **15:26** / 15:41）	投入テキスト ＋ 台本「§6 当日の流れ」
15:47	**スレッドで振り返り**（下書き → 一斉投稿 → その場で集約）	台本「§5 振り返り」
15:58	クロージングを投稿 → **配布資料とネタバラシを投稿**	配布資料 ＋ 投入テキスト
訓練後	集約をアクションに変換、チャンネルをアーカイブ	`2026-10-02_action-plan.md` ＋ 台本「§9」

事前準備（カレンダー登録用）

すべて台本 01_ファシリテーター用進行台本.pdf の「§2 事前準備」が出典。
文面が要るものは 02_Slack投入用テキスト.pdf にある。

期日	やること	担当	記載場所
～9/30（水）	**オブザーバー（経営層1名）を確保する**（可能なら）	空	台本 §2「前日までに」／§2「役割の割り当て」
9/30（水）	参加者へ案内を送る（「10/2 15:00～16:00 / 予習不要 / 会議は設定しない / Slackを見られる状態に」のみ）	空	台本 §2「前日までに」
9/30（水）	**シナリオは誰にも事前共有しない**（藤原さんも訓練の対象）。停止権限は空さんが持つ。オブザーバーを置ける場合のみ、その人にだけ共有する	空	台本 §2「前日までに」／投入テキスト「⚠️ 実施前に必ず読むこと」
10/1（木）	`#2026_個人情報漏えい訓練` を作成、**トピックに `【訓練用】ONBS-1998 机上訓練専用`**、参加者全員を招待	空	台本 §2「チャンネル構成」／投入テキスト「チャンネル構成」
—	~~canvas を作る~~ **不要。** 共有チャンネルに社内の時系列を貼らない。時系列は xlsx の Part1 へ	—	台本 §2「チャンネル構成」
10/1（木）	開始告知・クロージングの文面を用意し、インジェクト文面をコピペできる状態にしておく	空	投入テキスト 全体
10/2（金）14:45	**鈴木さんへDM**で役の情報を渡す（他の参加者には見せない）	空 → 鈴木	台本 §2「当日、開始前に」／投入テキスト「開始直前 — 鈴木さんへのDM」
10/2（金）14:50	全体チャンネルへ**訓練実施の周知**を投稿（既存チャンネルでのやり取りも起きる旨を含む）	空	投入テキスト「参加していないメンバーへの周知」
10/2（金）14:55	振り返りシート（xlsx）を開く。**配布資料はまだ投稿しない**	空	台本 §2「当日、開始前に」

社内対応用チャンネルは作らない。 参加者が自分で作るかどうかが観測点。

> 事前に読んでおくもの: 投入テキスト冒頭の「⚠️ 実施前に必ず読むこと」（厳守事項5点）と、
> 台本 §6「モードC（Slack完結型）の運用」。当日はこの2つが手元にあれば回せる。

シナリオの登場企業

呼び方	立場
A社	CSVを受け取り、混入を指摘してきた取引先
他社プロダクト3社	A社のCSVに混入していた、**データの持ち主**である顧客企業。各資料の「3社」はこれ
計5社	同じ期間に同じログインレポートをダウンロードした顧客（A社を含む）。**残り4社分は中身が未確定**という設定
B社	上記3社のうちの1社。インジェクト⑤で「A社経由で先に知った」として問い合わせてくる。**同じチャンネルへ投稿するため、直前に「場面転換アナウンス」を挟んで読み替える**（チャンネルは増やさない）
鈴木さんの役	**該当の集計ロジックを先月改修したエンジニア。**まだ自分の改修が原因だと結び付いていない
1,240名	3社のエンドユーザー。情報が漏えいした**該当者**（法律上の「本人」）。**報告件数は行数（48,000行）ではなくこちら**

守ること

- **実際のクライアントとのSlackチャンネル（Slack Connect含む）には絶対に投稿しない**
- 台本と投入テキストを参加者に渡さない。配布してよいのは終了後の配布資料だけ
- **訓練は必ずその日のうちに終了させ、ネタバラシまで行う**
- 参加者が本物のクライアントや社外に連絡しようとしたら、**即座に訓練であることを明かして止める**
- 訓練用チャンネルは**削除ではなくアーカイブ**する（訓練記録として残す）
